

Data Classification & Handling

Owner: Mark Stolte, Founder — markstolte02@gmail.com

Last reviewed: 2026-07-05

Stage: Pre-launch / active development

Purpose

Defines the sensitivity tiers Penny Pilot uses for its data, maps the data the app actually stores today into those tiers, and states the handling rule for each tier.

Tiers

Tier	Definition
Restricted	Data that would let someone access a user's money or impersonate them if exposed. Highest protection.
Confidential	Personal or financial data specific to a user, not directly usable to move money, but still private.
Internal	Operational data about the app itself, not tied to an identifiable user in a sensitive way.
Public	Anything intended for public consumption (marketing copy, App Store listing).

Data map

Data	Tier	Where it lives	Notes
Plaid access tokens	Restricted	<code>plaid_items.access_token</code> Application layer (Supabase Postgres)	Application layer AES-256-GCM encrypted; see Encryption Standards . Never sent to the client.
Supabase session tokens	Restricted	Device secure storage (Keychain/Keystore via <code>expo-secure-store</code>)	Grants API access as the user; treated like a credential.

Bank account numbers/routing	Restricted	Not stored by Penny Pilot at all	Plaid Link collects bank credentials directly with the institution; Penny Pilot never receives or stores raw account/routing numbers or bank login credentials.
Bank account balances, mask, institution name	Confidential	<code>bank_accounts</code> table	Needed for the product's core budgeting/forecasting features.
Transaction detail (merchant, amount, date, category)	Confidential	<code>transactions</code> table, or on-device only in <code>mock</code> /local-import mode	The core financial data of the product.
User email, display name	Confidential	<code>profiles</code> table (populated from the OAuth provider)	Minimal — Penny Pilot does not request additional profile scopes beyond what Apple/Google provide by default.
Merchant categorization rules, budget/goal configuration	Confidential	<code>merchant_rules</code> , <code>budgets</code> , <code>budget_lines</code> , <code>goals</code> tables	Reveals spending habits and financial goals even without raw transactions.
Locally-imported CSV/XLS bank exports (no-link path)	Confidential	Parsed on-device (<code>src/services/csv-import.ts</code>), persisted locally unless the user is in <code>supabase</code> mode	Chosen by users who don't want to link a bank account at all; handling should be at least as protective as synced data, not less.
Aggregated/anonymized categorization patterns	Internal	Not currently collected	docs/technical-architecture.md lists this as an open question. Until a specific anonymization approach and disclosure are defined and shipped, no cross-user learning happens, and none should.
App Store listing, marketing site, README	Public	GitHub, App Store Connect, Play Console	No handling restriction.

No cardholder data

Penny Pilot does not accept, process, or store payment card data (PAN, CVV, expiry) for end users' linked bank accounts — PCI DSS scope does not apply to that flow. (If Penny Pilot later adds paid subscriptions, that payment flow will go through a PCI-compliant

processor such as Apple/Google's in-app purchase or Stripe, and this document will be updated before that ships.)

Handling rules by tier

- **Restricted:** Encrypted at rest with an application-layer key the client never receives; never logged (see [Logging & Monitoring](#)); access limited to backend Edge Functions and the row's owning user via RLS; deleted when the corresponding Plaid item is removed or the account is deleted.
- **Confidential:** Protected by Supabase Row Level Security scoped to `auth.uid()` (`supabase/migrations/0001_initial_schema.sql`); transmitted only over TLS; retained for as long as the user's account exists, deleted on account deletion (see [Business Continuity & Disaster Recovery](#) for backup-retention interaction).
- **Internal:** Not yet collected; if introduced, must be genuinely de-identified before storage and disclosed in the app's privacy policy first.
- **Public:** No special handling.

Retention and deletion

Deleting a user's `profiles` row cascades to every dependent table (`setup_preferences`, `plaid_items`, `bank_accounts`, `categories`, `subcategories`, `transactions`, `merchant_rules`, `budgets`, `budget_lines`, `goals`, `forecast_snapshots`, `entitlements`) via `on delete cascade` foreign keys in the schema. Account deletion should also trigger a Plaid `/item/remove` call so the underlying bank connection is revoked at Plaid, not just locally deleted — this is a product requirement to track before general availability, not yet implemented as of this review.